CONTAINDER: Bounding Credential-Compromise Impact in IEEE 2030.5 DER Systems

Huan Bui*

University of North Carolina at Charlotte, Charlotte, NC, USA

Abstract

IEEE 2030.5 binds a distributed energy resource's long-lived bootstrap identity to its operational authorization and forbids online certificate revocation. A stolen credential therefore retains control authority indefinitely, and no online mechanism can withdraw it. We present CONTAINDER, which replaces the conflated device credential with attested, short-lived, scope-bound operational credentials and uses non-renewal rather than revocation as the containment mechanism, deployable incrementally through native and gateway-proxy tiers. Because reachability alone does not distinguish these designs, we measure impact along four dimensions — cyber reach, state-dependent commandable flexibility, retained authority, and feeder consequence — and give a worked example of two compromises with identical reach but divergent flexibility, persistence, and feeder outcome. We implement a credential service with real X.509 and mutual TLS and a real OpenDSS feeder pipeline. On the IEEE 8500-node feeder, ten implemented security invariants pass and attested issuance costs about 0.23 ms. Our central physical finding is that whether authorization narrowing contains a compromise depends on the *shape* of the authorized set, not on how tightly it is drawn. An adversary need inject nothing: at zero authorized reactive setpoint the induced overvoltage area still rises — by 31.2 p.u.-node under a fixed-setpoint override and 31.4 under a bounded volt-var curve — with

*Corresponding author.
Email address: hbui11@charlotte.edu (Huan Bui)

every seed tripping the IEEE 1547 overvoltage screen, because merely withdrawing the reactive absorption the feeder relies on is itself sufficient to breach the band. A bound of the form $|q| \leq q_{\max}$ admits zero at every width and therefore cannot contain, however tight; an authorization that instead holds the DER to at least about three quarters of the conformant Category B absorption trips no seed while still delivering volt-var. Both control primitives behave the same way on this band, so the design consequence is about the bound rather than the function set that carries it — authorize a reactive band that excludes zero absorption. Scope alone is still not sufficient at the envelope operators actually grant, so lifetime is the second control: across twenty paired seeds a compromise at the conformant envelope holds the feeder in violation for the whole horizon under a long-lived credential, whereas under CONTAINDER the feeder returns to its pre-attack baseline within one minute of expiry in 17 of 20 seeds under light load — though our fixed recovery threshold is too coarse to resolve the same question under normal load, and we report that. We show that integrated harm is the product of a measured accrual rate and the credential lifetime, so the containment factor is a lifetime the operator chooses rather than an effect size we measured, and we report its cost: a 51.5% rise in regulator tap operations. These are reduced-scale pilot results, reported as exploratory; the pre-registered confirmatory sweep is future work.
Keywords: Critical infrastructure protection, distributed energy resources, IEEE 2030.5, remote attestation, authorization, cyber-physical security

---

1. Introduction

Distributed energy resources now participate in grid operations at a scale that makes their control interface a systemic concern. IEEE 2030.5 (Smart Energy Profile 2.0), profiled for distribution use by the Common Smart Inverter Profile (CSIP), is the application protocol through which utilities and aggregators dispatch inverter-based resources. An adversary who obtains a credentialed identity in this ecosystem does not merely read data; it can command real and reactive power on physical hardware connected to the grid.

Two properties of the IEEE 2030.5 trust model make this worse than a conventional credential-theft problem. First, the device's bootstrap identity and its operational authorization are the same long-lived certificate: there is no separate, short-lived operational credential to lose. Second, the standard forbids certificate revocation; it directs that certificate authorities not maintain revocation lists or run status responders, and that clients and servers not check them [1]. A stolen credential is therefore valid until it expires, and its lifetime may be indefinite.

A natural objection is that this is a solved problem: model the DER authorization surface as a privilege graph and measure blast radius as reachability, as a mature line of work does for enterprise networks [2, 3, 4]. We argue this reduction is insufficient as ordinarily applied. What determines the damage of a DER compromise is not only which nodes an adversary can reach, but how much physical capacity those nodes command, how long the adversary retains that capacity, and what the feeder does in response under the grid state at the time. Reachability over a static privilege graph is a function of the attack locus and the graph alone; the quantities that matter are functions of the defensive policy and of exogenous physical state, and neither is topological.

Contributions

- *CONTAINDER*, an incrementally deployable credential redesign for IEEE 2030.5 using attested, short-lived, scope-bound operational credentials, with non-renewal as containment and explicit session- and command-effect enforcement, deployable through native and gateway-proxy tiers.

- A *working prototype* — a credential service with real X.509 issuance, mutual TLS, and renewal, plus an OpenDSS feeder pipeline — with ten implemented security invariants verified and containment timing measured.

- A *result about the shape a reactive authorization must have*: on the IEEE 8500-node feeder [5], an authorization that permits zero reactive absorption does not contain a compromise, because withdrawing the absorption the feeder depends on is by itself enough to breach the band and trip every seed — the adversary need inject nothing. A magnitude cap $|q| \leq q_{\max}$ admits zero at every width and so cannot contain, while a band holding the DER to roughly three quarters of the conformant Category B absorption trips no seed and still delivers volt-var. We measured this under both a fixed-setpoint override and a bounded volt-var curve and report that it does *not* separate them, against our own prior expectation that the primitive would matter. The apparent adequacy of a narrow access list in our earlier configuration was an artifact of an envelope too small to deliver the service at all.

- A *pilot evaluation* with paired per-seed contrasts over twenty seeds showing that, at that conformant scope, bounding the *duration* of retained authority is the only remaining control, and characterising it honestly: the mechanism truncates the exposure window rather than attenuating the excursion, so integrated harm is a measured accrual rate multiplied by the lifetime and the containment factor is a lifetime the operator chooses, not an effect size we measured. We report what it costs — a 51.5% rise in regulator tap operations — and where it does not pay, and we quantify the containment latency it buys: expected retention is the credential lifetime divided by the per-cycle attestation detection probability, not the lifetime itself.

The threat model separates bootstrap identity, operational credential, and authorization scope, and names the standard's conflation of the first two as the driver of unbounded persistence.

We deliberately do *not* claim the four-dimension accounting of Section 3 as a contribution. Adding resource-by-scope product nodes, a time index, and attached state and policy to a classical attack graph yields it, and the separation propositions it supports are true by construction, since a reachability-only measure cannot depend on variables that are not among its arguments. We keep the notation because the paper needs a vocabulary for how much, for how long, and under which grid conditions. It is not a theoretical advance, and the load-bearing claims here are empirical.

We state scope plainly. The engine, credential service, and feeder pipeline are implemented and covered by a regression suite. The evaluation is a pilot: one feeder, one solver, one workstation, and — at the conformant scope envelope where the central result lies — one penetration level and two operating states. The pre-registered confirmatory sweep, with a cross-solver check, constrained hardware, a stealth-constrained attacker, and the full seed budget, is future work.

2. Background and Threat Model

2.1. Authorization in IEEE 2030.5 / CSIP

IEEE 2030.5 uses mutual TLS with X.509 device certificates. A device's identity is the certificate-derived LFDI/SFDI, and its authorization is scoped by a `FunctionSetAssignments` resource that binds it to one or more `DERPrograms`. Physical control authority is carried by the `DERControlBase` control modes: active-power capping (`opModMaxLimW`), signed fixed active power for storage charge and discharge (`opModFixedW`), reactive power (`opModFixedVar`, `opModVoltVar`), volt-watt and frequency-watt curves, and the hard connect and energize controls [6]. The standard specifies certificate-based authentication and function-set scoping; it does not mandate a single canonical access-control object.

2.2. Certificate validity and revocation

The trust model has two properties central to this work [1]. Device certificates have indefinite lifetime, and revocation is prohibited: certificate authorities are directed not to maintain revocation lists or run status responders, and endpoints are directed not to check them. The stated reasons are concrete design constraints, not incidental — field devices have no guaranteed connectivity, a hard-fail check destroys availability while a soft-fail check is trivially bypassed by blocking the responder, revocation presupposes a secure time source that inverters may lack, and no party is defined as responsible for reporting a compromised device — and the sanctioned substitute is a local allow or deny list. The consequence for our threat model is direct: once a credential is compromised, there is no online mechanism to withdraw it, so its authority persists until it expires.

2.3. Three separated layers

We separate three layers that the baseline standard conflates. *L1, bootstrap identity*: the hardware-rooted device certificate. *L2, operational credential*: the credential that authorizes live sessions to an aggregator or DER management system. *L3, authorization scope*: the server-side binding from an identity to the function sets it may invoke. In baseline IEEE 2030.5, L1 and L2 are the same long-lived certificate, with no attestation gate and no revocation path. This conflation, not any single cryptographic weakness, is what makes a compromise persist for the certificate lifetime.

2.4. Compromise loci and adversary

We consider four compromise loci of increasing consequence: a single device, an edge gateway, an aggregator or DER management system, and a utility-side issuing role. The adversary obtains a valid credential at one locus — by key extraction, session theft, or a misconfigured server granting scope — and issues protocol-conformant control commands within that credential's authorization, without breaking TLS or the underlying cryptography. The issuing role is the ceiling on what any credential discipline can bound, since it can subvert issuance itself; we treat it as the boundary of the design's protection rather than a case it defeats.

2.5. Credential lifecycle and existing containment

The motivation depends on exact certificate-management behavior, which differs across editions: IEEE 2030.5-2018 [7], IEEE 2030.5-2023 [8] (which supersedes it, published December 2024), and the profile in force [9]. We separate four questions the literature tends to conflate: whether a certificate can be cryptographically revoked; whether a server can locally deny an identity despite a valid certificate; whether a device can be re-enrolled or re-keyed; and whether an active session or an already-issued control remains effective after credential expiry. Lack of CRL/OCSP bounds only the first.

The paper's primary open risk, stated plainly.. **We were unable to obtain IEEE 2030.5-2023.** It is paywalled at roughly US$255, is not in the IEEE GET free-standards programme, and we found no publicly accessible document quoting its clause text — every free source that quotes 2030.5 quotes the 2018 edition. Our premise, that a certificate's lifetime is effectively indefinite while online revocation is unavailable, is therefore evidenced against the *2018* edition and the Sandia analysis [1], not the edition in force. This is the single largest threat to the paper's external validity and we do not minimise it. Table 1 gives each claim's evidence row by row. Two rows matter most. **S5 is unsupported by any source we could access** and contradicted in spirit — Sandia lists dynamic re-provisioning as a recommendation, i.e. a capability judged absent — so we treat re-enrollment as something CONTAINDER must supply. **S8 is most exposed to edition drift**, since the 2023 revision is described as eliminating mandatory DERControl modes, exactly S8's territory.

2.6. Assets, adversary, and goals

Protected assets: DER control integrity, fleet authorization, operational and attestation keys, and feeder stability and service continuity. *Adversary capabilities:* steals an operational key (and, where tested, a bootstrap key), compromises firmware, steals an active session, compromises a gateway or aggregator, issues protocol-conformant commands, and observes authorized telemetry. *Exclusions:* breaking standard cryptography, physical destruction, and compromising both the root issuer and all audit controls, which we treat as the protection boundary rather than a defended case. *Security goals:* least authority, bounded new-session authority, bounded active-session authority, bounded

Table 1: Every standards claim the argument uses, the accessible source of record for it, and what remains unverified. **No row has been checked against IEEE 2030.5-2023**; the edition in force could not be obtained (see text). SAND = Sandia SAND2019-1490 [1]; CSIP = Common Smart Inverter Profile Implementation Guide v2.1 [9]. "Free source" means a document a reader can check without purchase.

ID	Claim	Free source of record	Residual risk
S1	Device certificate lifetime indefinite	SAND §4.1, verbatim	2023 clause unread
S2	CRL use prohibited	SAND §4.1, verbatim	2023 clause unread
S3	OCSP prohibited	SAND §4.1, verbatim	2023 clause unread
S4	Local allow/deny listing available	SAND §4.1, §3.1.1.3; CSIP §5.2.1.4	permitted, not required (SAND §3.1.1.4)
S5	Certificate replacement / re-enrollment possible	**none**	**unsupported**; SAND Rec. 5 implies absent
S6	LFDI/SFDI derives from certificate	SAND §3.1.1.1 and CSIP §5.2.1.2 (independent)	**low**; two sources agree
S7	FunctionSetAssignments scopes operations	CSIP §5.2.3.1	clause number only
S8	Scheduled DER controls can persist	CSIP §4.4.2, §6.1.8.2	**high**; 2023 reportedly drops mandatory DERControl modes

command-effect duration, fresh-key containment, replay resistance, safe degradation, and auditability. *Non-goals:* defending against malicious root issuance without added governance, detecting every hardware attack, replacing grid protection, and proving safety for every feeder.

3. Impact Accounting, and Why Reachability Alone Cannot Rank These Designs

This section fixes notation and says why we need it. As the introduction states, it is *not* a contribution: an extended attack graph [10, 3, 11] yields exactly the accounting below and so agrees with us rather than competing. We keep the notation only because the experiments in Section 8 move "how much", "for how long", and "under which grid conditions" differently, and one scalar cannot express that.

Substrate and the four quantities.. A static privilege graph $G = (V, E)$ has principals and resources as nodes and access relations as edges; $x \subseteq V$ is a set of compromised credentials, and a policy $\pi = (L, \mathrm{Att}, A)$ gives a lifetime function L, an attestation-gated renewal predicate Att, and a scope map A. The device and grid state u_t and the feeder power-flow and protection model F appear nowhere in G, which is the point.

Cyber reach $\mathrm{BR}_{\mathrm{reach}} = \mathrm{ReachSet}(x, \pi)$, a count, is the least fixed point of the π-enabled access relation from x: the endpoints the compromised authority can send an authenticated request to. *Commandable flexibility* $\mathrm{BR}_{\mathrm{flex}}$, in kW and kVAr, is the aggregate over reachable DERs of the feasible set-point region $\mathcal{C}_d(t; u_t, A_\pi(d))$ given irradiance, state of charge, and inverter limits; a read-only scope yields the current set-point alone, hence zero. *Retained authority* separates three durations, in seconds,

$$\mathrm{BR}_{\mathrm{auth}} = \max\left(T_{\mathrm{cred}}, T_{\mathrm{sess}}, T_{\mathrm{cmd}}\right), \tag{1}$$

where T_{cred} runs until the stolen credential is refused for a *new* session, T_{sess} until already-authenticated sessions can no longer issue commands, and T_{cmd} until queued or latched controls stop affecting the DER; the capacity-time exposure $\mathrm{BR}_{\mathrm{exp}} = \int \mathrm{BR}_{\mathrm{flex}}(t)\, \mathbf{1}[\text{authority effective}]\, dt$ carries kW·h or kVAr·h. This split is the design's load-bearing one: expiry bounds T_{cred} only. *Physical consequence* $\mathrm{BR}_{\mathrm{phys}} = \max_a J_V(F, u, a)$ is the worst outcome reachable within the adversary's authority, where J_V is the voltage-violation area outside the ANSI C84.1 band weighted by magnitude. $\mathrm{BR}_{\mathrm{phys}}$ carries two units and we label every table with which: *p.u.-node* evaluated at one operating point, and *p.u.-node-min* accumulated over a horizon. Secondary metrics are maximum per-unit deviation, violating-node count, protection trips, regulator tap operations, energy not served, unnecessary curtailment, and recovery time.

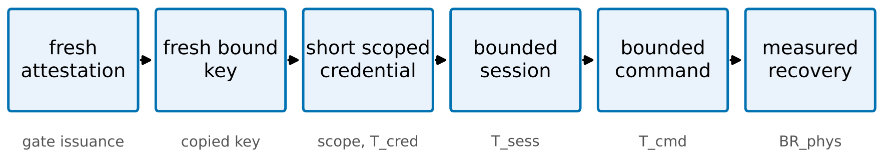

Figure 1: The CONTAINDER containment chain. Each link bounds a dimension: attestation gates issuance, fresh-key binding contains a copied key, scope and short lifetime bound $\mathrm{BR}_{\mathrm{flex}}$ and T_{cred}, session and command enforcement bound T_{sess} and T_{cmd}, and measured recovery bounds $\mathrm{BR}_{\mathrm{phys}}$.

Three separations, true by construction.. Call a measurement *reachability-only* if it is a function M of $\mathrm{ReachSet}(x)$ alone. Then, at fixed reachable set, varying the scope map changes $\mathrm{BR}_{\mathrm{flex}}$; an attestation-gated ephemeral credential and a long-lived unrevoked one differ in $\mathrm{BR}_{\mathrm{auth}}$ and $\mathrm{BR}_{\mathrm{exp}}$; and the same authorized command is harmless at one operating state and trips the IEEE 1547 overvoltage screen at another. **None of these can fail**, since M is single-valued in $\mathrm{ReachSet}(x)$ and each construction varies a quantity that is by definition not an argument of M. They restate a definition. We keep them only because they say which quantities an evaluation must move, and each ships as a regression test in the released engine. **They are not evidence for the design; that is in Section 8, and only there.**

4. CONTAINDER Design

CONTAINDER separates the layers that IEEE 2030.5 conflates and enforces credential lifetime at the session and command layers, not only at issuance. The design is a containment chain: fresh attestation, a fresh hardware-bound key, a short scoped operational credential, a bounded session, and a bounded command effect, so that removing authority actually removes control. Each link targets a dimension of the model (Fig. 1).

4.1. Components and trust layering

The device keeps a long-lived, hardware-rooted bootstrap identity [12] used only for enrollment and attestation, never accepted directly for DER control. An *attester* produces fresh evidence bound to a freshly generated operational public key; a *verifier* checks evidence against endorsement and reference values and returns an explicit result; a *credential issuer* signs a short-lived operational certificate embedding role, site, scope, and expiry only for a valid attestation result; an *authorization service* maps the operational identity to least-privilege function-set assignments; the *2030.5 server or proxy* authenticates the operational certificate, enforces a maximum session age, and rechecks authorization per command or at a bounded interval; a *session controller* and a *command-lifecycle controller* bound authority beyond expiry; and a *risk controller* selects deny, scope narrowing, or bounded emergency renewal. We use the Entity Attestation Token [13] under the RATS Attester/Verifier/Relying-Party model [14], and define a concrete EAT profile rather than treating EAT as a complete attestation protocol.

4.2. Fresh-key binding

Attesting a device is not sufficient: a healthy device can pass attestation while an attacker retains a previously copied operational key. CONTAINDER therefore requires that every credential epoch use a newly generated operational key, generated in a TPM, TEE, or secure element where available and marked non-exportable, whose public-key digest is carried in the attestation evidence. The issuer signs only the attested public key, refuses renewal that presents only a prior certificate, rejects replayed evidence and reused nonces, and rotates the key even when the device stays healthy. This is what contains a copied key across the next epoch.

4.3. Session and command-effect enforcement

Certificate expiry does not end an open TLS session or an already-issued long-duration control. CONTAINDER closes sessions at credential expiry (or

Table 2: Safe-mode authorization states.

State	Allowed	Denied
Healthy	normal scoped control	out-of-scope control
Verification delayed	read telemetry, hold last safe schedule	new high-impact dispatch
Attestation uncertain	read-only, bounded emergency control	arbitrary set-points
Known compromise	read-only or total denial	all control
Issuer outage	prior low-risk scope, bounded grace	scope expansion, high impact

bounds session age to the credential TTL) and revalidates authorization per command, and it bounds adversary-issued controls through a maximum command duration, cancellation on containment, and safe-default restoration, with explicit handling of scheduled DERControls. The two quantities the prototype measures are

$$\Delta_{\text{expiry}} = t_{\text{last adv. command}} - t_{\text{expiry}}, \tag{2}$$

$$\Delta_{\text{effect}} = t_{\text{effect ends}} - t_{\text{expiry}}, \tag{3}$$

each targeted to zero or a small declared bound. These are exactly the T_{sess} and T_{cmd} components of BR_{auth}.

4.4. Safe-mode policy

Failure behavior is explicit rather than fail-open. The risk controller chooses among the states in Table 2; no failure mode grants indefinite authority, and the safety of each degraded state is validated under feeder conditions rather than assumed.

4.5. Migration compatibility

We separate three compatibility levels — *protocol* (2030.5 messages stay conformant), *implementation* (unmodified client or server software can participate), and *deployment* (legacy and upgraded devices coexist) — and claim none of them without a passing interoperability test rather than asserting "backward compatible." None has yet been tested; Section 8 reports interoperability as untested. Three tiers realize this: a bootstrap-only legacy tier, a gateway-attested proxy tier where an edge gateway holds the operational credential for downstream legacy devices, and a native device-attested tier.

4.6. What non-renewal inherits from the constraints it cites

Section 2 adopts the Sandia analysis's reasons why online revocation fails for DER: no guaranteed connectivity, no trustworthy time on inverters, and no responsible reporting party. Our mechanism inherits two of the three, and we state that rather than let a reader find it.

Secure time. Expiry is a judgment about time, so an endpoint that cannot trust its clock cannot enforce a short lifetime — the deficiency cited against OCSP — and a skewed device clock would extend a "short-lived" credential indefinitely. So **expiry is never enforced by the endpoint alone**: the issuer refuses renewal server-side where a trustworthy clock exists, each renewal binds a fresh key to a verifier-supplied nonce so a replayed attestation cannot extend authority however the clock reads, and session and command limits are monotonic counters rather than wall-clock deadlines. A skewed clock then costs availability, not containment. We have not measured skew.

Connectivity. A twelve-hour lifetime means a DER losing backhaul for twelve hours loses control authority, and rural outages of that length are routine. An aggregator that drops a fifth of fleet controllability during a verifier outage has created a reliability hazard while closing a security one. Safe-mode degradation to an autonomous volt-var profile exists for this reason; whether the trade is acceptable is an operator's call. Our availability figures come from in-process injection, not networked outages, and renewal storms are untested.

Who reports compromise. Attestation detects only what it measures. Firmware integrity is measurable; **a stolen operational key on a device with intact firmware passes attestation**. Per-epoch fresh-key binding answers this, but containment latency is then not the lifetime: with per-cycle detection probability p and lifetime T, expected retention is T/p — twelve hours at T=6 h, p=0.5, and equal to T only at p=1. **We report T/p as the containment-latency figure of merit.** The alternative, a narrow access list on a long-lived credential, contains a copied key only when someone notices and edits the list, which has no bounded latency at all. Bounded beats unbounded; it does not beat instant.

Which tier is deployable. Presenting three tiers evenhandedly would mislead: only one is deployable within the next standards cycle. The native tier needs attestation and a trusted clock on constrained inverter hardware; the legacy tier changes nothing. **The gateway-attested proxy tier resolves all three inheritances at once** — the gateway holds the credential and the clock, attestation runs on capable hardware, downstream devices stay unmodified, and short outages are buffered — and it alone requires no change to already-certified endpoints. We regard it as the deployment path.

4.7. Implementation status

The design is realized as an issuance and renewal service using real X.509 certificates and mutual TLS, with a Python IEEE 2030.5-style client in place of the EPRI C client and structured event logging for every credential, session, and command transition. Its security invariants and workstation overhead are reported in Section 8; a native EPRI-client integration and constrained-hardware measurements remain future work.

5. Cyber-Side Analysis Engine

We implement the cyber-side impact dimensions as an analysis engine, `pkimodel`, that computes $\mathrm{BR}_{\mathrm{reach}}$, $\mathrm{BR}_{\mathrm{flex}}$, and $\mathrm{BR}_{\mathrm{auth}}$ for a compromise locus under a policy. The engine models the identity and delegation graph over the six node types of the threat model, with typed issuance, delegation, and authorization edges. Its central modeling choice follows the formalism: a credential's reach (which DERs it can address) is represented independently of its scope (which function sets it may invoke at each DER). This is what makes the separating counterexample expressible in code, and we ship that counterexample as a regression test: the two compromises resolve to an identical reachable set of eleven DERs, yet the engine computes zero commandable kW for the attested credential against tens of MW for the legacy one, and a persistence of hours against the analysis horizon.

The authorization policy is parameterized, not fixed: a hardcoded permissive access model would overstate what a stolen certificate can command, so the engine exposes four ACL realism levels spanning single-device, site, feeder-segment, and whole-fleet scope, varied in the evaluation. On a synthetic 200-device fleet over four feeders the reachable-DER count grows from one (single-device and site) to fifty (feeder) to two hundred (fleet), with commandable capacity in step; the feeder-level figure is the fleet divided by the feeder count and moves with that parameter. This operationalizes RQ1: most reach gained by a compromise is attributable to authorization scope rather than to authentication alone. Retained authority is returned as a distribution over duration, not a point estimate, and separates credential, session, and command-effect components.

The engine consumes synthetic scenarios from a deterministic, seedable generator, since real utility authorization graphs are not public; the generator is released as part of the artifact. The engine is cyber-side only. It produces the reachable-DER set and the commandable-capacity envelope that the feeder simulation consumes to compute $\mathrm{BR}_{\mathrm{phys}}$.

6. Feeder Simulation Methodology

The physical consequence dimension is measured by a feeder simulation that translates an authorized-control reach from the analysis engine into a malicious dispatch program and runs it on a public distribution feeder. We take the IEEE 8500-node feeder [5] as the primary benchmark and the PNNL 9500-node system [15] as an advanced validation tier — the latter did not converge in our build and contributes no reported number, a failure mode we name in Section 8. Time-series inputs come from public solar and load datasets. This part of the work is methodologically routine relative to the false-data-injection literature on distribution systems, so we build it to be unimpeachable rather than novel.

This is a single-solver study, and we state the consequence rather than the aspiration: the authorization envelope is applied directly in the OpenDSS driver, so the constraint a credential expresses is enforced on the dispatch that actually reaches the feeder, but no second solver corroborates the result. Section 8 reports what that costs. The attack families are volt-var curve distortion, volt-watt curve distortion, export-limit distortion, and curtailment spam; the metrics are those of Section 3, with the per-unit voltage excursion as the primary continuous measure and a protection-trip flag as the discrete outcome.

Two feeder models, and which results use which.. Results in this paper come from two OpenDSS harnesses, and we say plainly which produced what rather than describe only the better one.

The corrected model (`power/feeder8500v2.py`) builds the fleet from `PVSystem` objects with an inverter rating and an `InvControl` volt-var controller on the IEEE 1547-2018 Category B default characteristic [16], and takes as its counterfactual the PV dispatched at its *legitimate scheduled output* under that curve. The scope-envelope sweep, the volt-var-curve sweep, the time series and the lifetime sweep use it.

The superseded model (`power/feeder8500.py`) used `Generator` objects at fixed P, Q — no inverter, no curve — against a counterfactual with every unit at $P{=}Q{=}0$, so its ΔJ_V conflates "connect this much generation" with "a credential was stolen", and a "volt-var curve distortion" attack under it was really a static setpoint delta. The PV-penetration, attack-family, IEEE 123 and retained-authority sweeps were run under it and are reported in Section 8 with that provenance attached. ΔJ_V **is therefore not on a common footing across every table**, and each table states which counterfactual its numbers use.

How the adversary acts on the reactive axis. Two distinct models appear, and the distinction turns out to matter (Section 8). Under *setpoint override* the autonomous controller is switched off and a fixed reactive setpoint is written, which is how a `opModFixedVar` command supersedes an active volt-var curve. Under *curve modification* the controller stays enabled and the adversary rewrites the characteristic within whatever band its authorization allows. The two express different authorizations, and an envelope bound means something different in each.

Control mode. We solve with `controlmode=static`, which does *not* disable the feeder's controls, and we release the diagnostic that shows it (`results/controlmode.json`). Reaching the legitimate base case at light load moves 8 of the 12 regulators, for 32 tap steps, and changes 6 capacitor states; a full-scope attack then moves 11 regulators for a further 24 tap steps and 3 capacitor changes. Controls are inert only under `controlmode=off`, where the same attack drives the total overvoltage area to 998.0 p.u.-node and $v_{\max}$ to 1.3145 p.u., against 133.1 p.u.-node and 1.1282 p.u. with controls active — the feeder's own regulation absorbs a factor of 7.5. Both figures in that comparison are total areas, not attack-minus-base differences, so that they are commensurable. Regulators and capacitors therefore act against the disturbance in every result reported, and we report tap operations throughout, including where CONTAINDER increases them.

Protection. Every node is screened against the IEEE 1547-2018 Category II overvoltage trip thresholds (OV2 1.20 p.u./0.16 s; OV1 1.10 p.u./2.0 s), plus a substation reverse-power flag. Earlier versions declared a trip metric with no protection model behind it, so it could never fire and any claim resting on it was unsupported.

We do not tune feeder parameters to amplify impact; we report what the standard models produce. A first benchmark run on the IEEE 8500-node feeder appears in the pilot evaluation; the full sweep on both feeders, with the GridLAB-D cross-check and seasonal operating states, follows the pre-registered protocol.

7. Evaluation Protocol (Pre-Registered)

No measured results are reported in this section. We state the evaluation protocol for the confirmatory sweep, and we state precisely what our immutability evidence for it is worth, because a pre-registration that overstates its own guarantee is worse than none.

The scenario matrix and statistical plan are recorded in `PREREGISTRATION.md` with a SHA-256 content hash recomputable by `validate_matrix.py`. **That hash is not a timestamp.** It was computed by the same party who could have edited the file, so it shows only that the matrix has not changed since the hash was written; it cannot show *when* the matrix was fixed relative to seeing any outcome. The repository's version-control anchor does not repair this: the initial commit capturing the pre-registration is dated 2026-07-30, which **postdates every pilot result reported in Section 8**. We therefore make no claim that the design could not have been adjusted after seeing pilot outcomes. It could have been, and no artifact in this repository proves otherwise.

The consequence follows directly, and we adopt it without qualification: the measured results in Section 8 are reported as **exploratory**, not confirmatory, and are excluded from the confirmatory tests.

Baselines and mechanism ablations.. Six credential-lifecycle designs are compared: legacy identity-as-authority (B1), legacy with a narrow access list (B2), ephemeral-only (B3), attestation-only (B4), full CONTAINDER (B5), and safe-mode renewal (B6). Each baseline is specified by explicit fresh-key, session-enforcement, and command-cleanup attributes, because the central claim is that short lifetime alone does not contain a copied key, an active session, or a persistent command. Eight mechanism ablations (A1–A8) each remove one link of the containment chain, so the measured reduction is attributed to a mechanism rather than to shorter certificates. Table 3 gives the baseline mechanism attributes.

Table 3: Credential-lifecycle baselines *as pre-registered.* FK = fresh key per epoch; Sess = session enforcement; Cmd = command-effect cleanup. "Narrow" here is a design category, not a value: the executed pilot instantiated it at two different envelopes, and Section 8 reports every result by the commanded kvar rather than by this label.

ID	Design	Lifetime	Attestation	Scope	FK	Sess	Cmd
B1	legacy identity-as-authority	long	no	deployment ACL	no	no	no
B2	legacy + narrow ACL	long	no	narrow	no	no	no
B3	ephemeral-only	short	no	reference	opt.	expiry	opt.
B4	attestation-only	long	yes	reference	enroll	weak	no
B5	full CONTAINDER	short	yes	narrow	per-epoch	yes	yes
B6	CONTAINDER safe-mode	short	yes	narrow/degraded	per-epoch	yes	yes

Factors and design.. The factors are credential time to live, authorization scope, compromise locus (with the issuer treated as a trust boundary, not a defended case), DER penetration and technology mix, attack program, attestation-trust state, renewal policy, and operating state. Every attack runs under both a worst-case optimizing attacker and an operationally realistic telemetry-limited attacker, so no result is only an omniscient upper bound. The primary comparison is the fully-crossed lifetime-by-scope factorial, whose interaction term is the compositional claim.

Statistics.. The experimental unit is the complete paired scenario run, not the per-timestep sample. The primary voltage-violation area is analyzed with a mixed-effects model, $\log(1+Y) = \beta_0 + \beta_1 \log(\mathrm{TTL}) + \beta_2\,\mathrm{Scope} + \beta_3 \log(\mathrm{TTL}) \times \mathrm{Scope} + b_{\mathrm{day}} + b_{\mathrm{seed}} + \epsilon$, whose interaction coefficient tests the primary hypothesis, with robust, aligned-rank, or permutation fallbacks where assumptions fail. Protection trips use mixed-effects logistic regression — now a well-defined outcome, since Section 6 implements a protection model — violating-node counts a negative-binomial mixed model, and recovery time survival analysis. Effect sizes are the median paired difference, ratio of geometric means, paired rank-biserial correlation, and odds ratios, each with bootstrap confidence intervals, with Holm correction within rather than across hypothesis families. A five-seed pilot and a power analysis set the production seed count before final comparisons are viewed. These procedures apply to the confirmatory sweep. The pilot in Section 8 reports paired per-seed contrasts with bootstrap intervals, which its stored data do support, and does not report the mixed-effects estimates, which they do not.

8. Pilot Evaluation

This pilot exercises the full pipeline end to end and produces measured results at deliberately limited scale. The cyber-side engine, credential service, OpenDSS feeder pipeline and availability fault injection are implemented and measured on a workstation, using the real IEEE 8500-node feeder [5]; native EPRI-client traffic, constrained-hardware attestation, a GridLAB-D cross-check, a HELICS federation, interoperability tests and the full pre-registered sweep are not. These results establish that the mechanism and the measurement work but do not replace the confirmatory sweep; the limitations paragraph closing this section states what each reaches.

Throughout, the primary physical endpoint is the *induced overvoltage area* ΔJ_V: the attack-case value of the one-sided overvoltage term of J_V, summed over all energized nodes as $\sum_i \max(0, V_i - 1.05)$, minus its base-case value at the same load state. Positive values mean the attack pushed nodes above the ANSI C84.1 upper band [17]. A single power-flow solution yields ΔJ_V in per-unit nodes (p.u.-node); the time-series experiment integrates the same quantity over a one-minute step, in per-unit node-minutes (p.u.-node-min). Each table and figure is labelled with the unit it carries.

Functional invariants and containment (C1, C2).. The credential service uses real X.509 / ECDSA certificates and an EAT-style attestation token. Ten implemented security invariants all pass on the prototype: bootstrap identity cannot authorize control, issuance requires a valid fresh attestation, the certificate is bound to a freshly generated operational key, replayed evidence is rejected, an expired credential cannot issue commands, per-command scope matches issuance, a bad measurement yields only a narrowed safe-mode scope, a prior

Table 4: Security invariants implemented by the prototype (real X.509/mTLS). All ten pass. The identifiers in `results/credsvc.json` match the IDs below; an earlier release numbered them I1–I5 and I7–I11, skipping I6, and the artifact has been renumbered.

ID	Invariant	Result
I1	Bootstrap identity cannot authorize control	pass
I2	Issuance requires a fresh attestation	pass
I3	Credential bound to a fresh public key	pass
I4	Replayed evidence rejected	pass
I5	Expired credential cannot issue a command	pass
I6	Scope enforced per command	pass
I7	Bad measurement yields degraded/denied scope	pass
I8	Prior epoch cannot self-renew	pass
I9	Copied prior key fails after rotation	pass
I10	Active session/command bounded past expiry	pass

epoch cannot self-renew, and a copied prior operational key is contained at the next epoch. Enforcement is checked functionally rather than measured: probing at +5.0 s past expiry, the per-command revalidation path refuses, giving $\Delta_{\text{expiry}} = -0.5\,\text{s}$ (the last accepted adversarial command precedes expiry), while the same probe against a cached session succeeds at the full +5.0 s. Both numbers are set by the probe offset and the configured session cache, so they establish that the enforcement path works, not how large a gap would be in deployment. A fresh operational key is generated each epoch, so a copied key is useless after rotation. Table 4 lists the invariants, the identifier each carries in the released result file, and their outcomes. These are the invariants the prototype implements and tests; they are not a proof of the design, and properties outside this set are untested.

Overhead (C3).. On the workstation tier, over 500 iterations, median software-path latencies are 0.03 ms for key generation, 0.06 ms for attestation construction, 0.23 ms for a full attested issuance and 2.3 ms for a real mutual-TLS handshake, and the issuer sustains about 4900 renewals per second single-threaded.

These are standard EC P-256 primitives dominated by one ECDSA signature and verification, so constrained-controller cost can be estimated from public-key throughput. They are software-path timings, not deployment latencies, and no hardware-backed measurement exists.

Availability (C6).. Renewal is fast enough not to be the binding constraint: a 100,000-device fleet re-mints in about 20 s at the measured issuer throughput. We claim nothing from the renewal safety margin $T_{\mathrm{TTL}} - (T_{\mathrm{renew,p99}} + T_{\mathrm{net}})$: with a p99 renewal of 0.7 ms and a flat 1 s network allowance it cannot be negative at any lifetime we tested, so it tests nothing, and the real question — margin under a realistic wide-area latency distribution and a renewal storm — is unmeasured. The binding risk is a verifier outage longer than the lifetime. Injecting verifier outages, fail-closed denial retains 0.77 of legitimate control availability, a bounded grace period 0.83, and degraded-scope safe mode 1.0. The injection is in-process; networked outages, clock skew, and renewal storms remain.

Time-series containment: what the lifetime mechanism does, and what its ratio is not (C5).. A compromised credential drives the DER from minute five of a sixty-minute horizon on the real IEEE 8500-node feeder, and its lifetime determines whether the malicious setpoint keeps reaching the feeder. Every (state, seed, policy) arm is an *independent* compile with a fresh PV fleet and fresh regulator and capacitor state, at twenty paired seeds and two operating states. That isolation matters: the predecessor compiled once per seed and iterated policies against the same live circuit, so each arm warm-started from the previous arm's excursion, and the integrals an earlier version reported (6956, 7030, 3196, 3.8) inherit that leak. **We withdraw all four.** Non-convergence is retried at most twice, tripling the control-iteration budget each time ($500 \to 1500 \to 4500$); 24 solves were flagged and 48 retried, and unsettled solves are retained and flagged, never dropped. **Every flagged solve falls in a lifetime-bounded arm of a single seed** (light load, seed 1019: nine steps in B3 and A4, six in B5, none in any long-lived arm), so we report recovery below both with and without it.

Results below are at the conformant Category B envelope of 5.28 kvar — the envelope an operator must authorize to receive volt-var at all (Table 6).

Scope alone does not contain. A long-lived credential confined to that envelope holds the feeder in violation for the entire horizon in 20/20 seeds, median integral 5656 p.u.-node-min (bootstrap CI [5356, 5857], light load; Fig. 2).

The mechanism truncates rather than attenuates. While the setpoint is applied the instantaneous excess area holds at a mean of 101.8 p.u.-node (SD 10.4). That the CONTAINDER and legacy arms accrue harm at the same rate is *not* a measurement: at equal scope they execute the identical trajectory until expiry, lifetime being the only parameter separating them, and the paired per-minute accrual is correspondingly identical to machine precision — worth reporting only as a check that the independent per-arm recompiles are deterministic. Nothing in the mechanism attenuates the setpoint while it is honoured; it only stops it.

Recovery is prompt, under light load. This could have come out otherwise: at expiry the feeder returns to its pre-attack baseline within one minute in 17/20 seeds (16/19 excluding seed 1019), the settled post-expiry excess has median 0.000 p.u.-node, and the whole post-expiry contribution is 1.74% of the integral. A regulator or capacitor left in an excursion-driven position could have held voltage up after the credential died, which would have made the mechanism useless; nothing latches. **Under normal load the criterion fails and we report that rather than the favourable state alone**: the same seeds and arms recover in only 2/20, with settled excess 0.193 and a 5.57% tail. We read this as a defect in our endpoint, not in the mechanism — recovery is declared below a fixed 0.05 p.u.-node while the normal-load baseline is itself 0.152, so the threshold sits inside the feeder's own variation. A relative criterion is what the confirmatory sweep should use, and until then this experiment speaks only to light load.

The "2.16× reduction" is therefore not an effect size, and we do not report it as one. The integral is the accrual rate times the minutes the credential is honoured, so the ratio is pinned to the ratio of exposure windows, $(60-5)/25 = 2.20$, net of the recovery tail. The mean ratio is 2.159 at the conformant envelope *and*

2.159 at the 3.6 kvar one, whose accrual rates differ by 43.7%, and no seed anywhere exceeds 2.1988. A physical mechanism does not return the same ratio at two different operating points; arithmetic does. *We therefore measure the relation instead.* Sweeping the lifetime over $\{5, 10, 15, 25, 40, 55\}$ minutes at twenty paired seeds, integrated harm is linear in lifetime at slope 100.4 p.u.-node-min per minute of retained validity at the conformant envelope ($R^2 = 0.965$) and 70.0 at 3.6 kvar ($R^2 = 0.960$) — the two accrual rates, recovered independently — while at the inert 0.6 kvar envelope the slope is -1.7 ($R^2 = 0.081$), lifetime buying nothing where the envelope does nothing. Two checks fall out: a 55-minute lifetime outlives the exposure window and reproduces the legacy arm exactly (5608.235), and tap operations sit at 102 at every lifetime expiring inside the horizon but 67 at 55 minutes, confirming the tap cost is the expiry transition and not the attack. The containment factor an operator obtains is thus (exposure window)/T_{cred}: a lifetime they choose against an exposure window set by their detection and response time, not an effect size we measured. (75 solves flagged in this sweep, 150 retried, all retained.)

The honest counter-arm, and the cost. At the non-conformant 0.6 kvar envelope the ordering reverses: CONTAINDER is *worse* than legacy (median 20.1 against 12.4; ratio 0.622, CI $[0.455, 0.781]$; 0/20 seeds favour it, and 0/20 at ratio 0.083 under normal load). Where the envelope is already inert the lifecycle buys nothing and the transition at expiry costs something: tap operations rise from a median of 78.5 to 125, a 59.2% increase. The same cost appears at the conformant envelope, 67 to 101.5, a 51.5% rise in regulator wear the voltage endpoint does not price. Lifetime enforcement pays only where scope cannot contain, which is precisely the conformant case — but it is not free.

Two arms withdrawn as uninformative. The ablations A2 and A3 are **not identified by this harness**: its activity predicate maps the `legacy`, `no_session` and `no_cleanup` lifecycles onto one branch, so A2, A3 and B1 are a single arm under three labels — their twenty-seed output series are byte-identical in both states — and A4 and B3 likewise. The earlier claim that removing session enforcement or command cleanup "returns the feeder to no

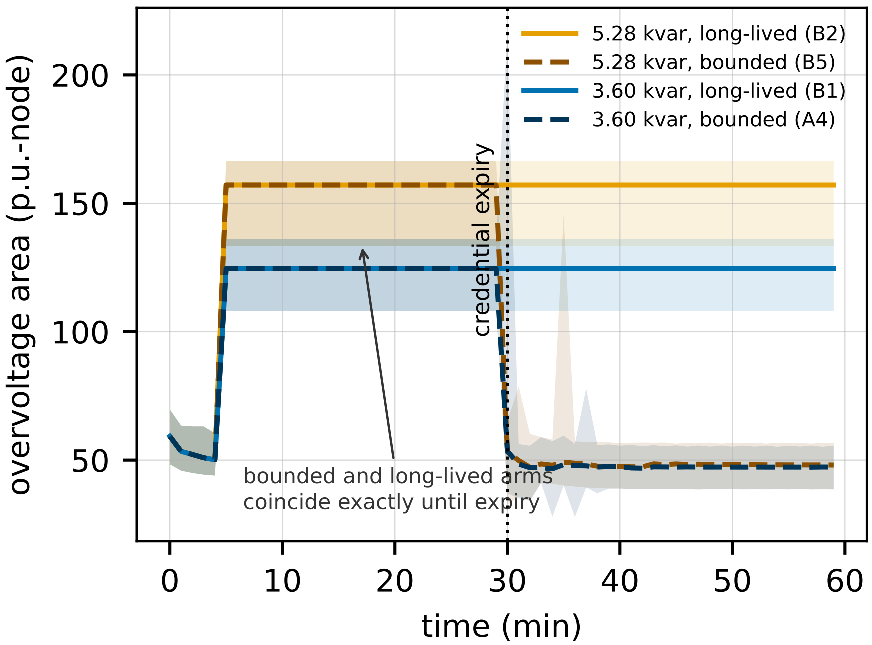

Figure 2: *Total* overvoltage area (p.u.-node) against time — not the excess above baseline that the integrals in the text sum. IEEE 8500, light load: median over n=20 paired seeds, min–max band shaded, each arm an independent compile. Colour is the authorized envelope, style the credential lifetime. The long-lived arms never recover (20/20 seeds each); the bounded arms track them *exactly* until expiry at minute 30, then return to baseline within one minute. The mechanism truncates the exposure window rather than attenuating the excursion, so the ratio of the integrals is set by the lifetime chosen against the horizon (see text).

recovery, so each mechanism is necessary" read a relabelling as a result, and we withdraw it. What those ablations were meant to probe is tested on the cyber side instead, by invariants I5, I6 and I10.

A label correction. The arm the artifact calls "full scope" commands 3.6 kvar while the one it calls "narrow ACL at IEEE 1547" commands 5.28 kvar, the inverter's own reactive limit — so "narrow" is a strict *superset* of "full", which is why the legacy arm reads 5656 at the conformant envelope against 3851 at the narrower one. That is an inverted label, not narrowing making things worse, and no comparison here reads a scope *ordering* off those two arms.

Feeder and endpoint.. The IEEE 8500-node feeder carries 4876 buses, 8531 nodes, 1177 loads and 10.8 MW of aggregate load at nominal multiplier; we place 600 seeded rooftop-PV units of 12 kW (7.2 MW). Because the 8500 base has native undervoltage at its extremities, we report the induced *overvoltage* area the attack targets rather than a two-sided area that would credit the attack for lifting sagging nodes — an attack-specific endpoint chosen after observing that undervoltage, while the two-sided area remains the declared primary system-level endpoint. In every result below ΔJ_V is measured against *legitimate scheduled PV under an IEEE 1547-2018 Category B volt-var curve*, not against a feeder with no DER.

How narrow must scope be before it stops containing? (C5). Fixing two envelopes by fiat cannot answer this, so we sweep the authorized envelope continuously along the two axes an IEEE 2030.5 `FunctionSetAssignments` narrowing can act on, at five paired seeds and two operating states (Table 6).

The state these numbers are measured in. Light load places 7.2 MW of PV against 3.24 MW of load — 222% **penetration** — and there the *legitimate* feeder, unattacked under the conformant curve, already carries a median overvoltage area of 57.7 p.u.-node with 5293 of 8531 nodes (62%) above 1.05 p.u., against 1.7 with the PV commanded to zero. Every ΔJ_V below is an increment on that, so "return to baseline" in this paper means a return to a non-compliant baseline, and the reactive result is measured where volt-var is already failing to hold the band unaided — a hosting-capacity condition as much as an authorization one. It trips in no seed, so the induced trips reported below are genuinely induced. Under normal load (67% penetration) the legitimate base area is 0.36.

On the *active-power* axis, where the adversary holds `DERControl`, there is a genuine threshold: under light load ΔJ_V stays negative up to σ=0.7 of nameplate and turns positive between σ=0.7 and σ=0.8, with the IEEE 1547 trip screen firing in 60% of seeds at σ=0.7 and in every seed from σ=0.8. Restricting active-power authority below roughly 70% of nameplate does contain.

On the *reactive* axis the answer depends on the *shape* of the authorized set rather than on its width, and it does *not* depend on which control primitive carries it. We evaluate two authorization models at matched reactive magnitude (Table 5, `run_curve_envelope.py`, five paired seeds, two states): *setpoint override*, in which an `opModFixedVar` command supersedes the active volt-var curve, and *curve modification*, in which the controller stays enabled and only the high-voltage reactive setpoint of the characteristic moves.

An authorization that permits zero absorption does not contain, under either primitive. At a commanded high-voltage reactive setpoint of zero the induced area rises by 31.2 under override and by 31.4 under curve modification, and every seed trips in both. This is the result worth stating plainly, and it is the one that survives: **an adversary need inject nothing.** Withdrawing the reactive absorption the feeder was relying on is by itself sufficient to breach the band and fire the trip screen, so a bound of the form $|q| \leq q_{\max}$ — which contains zero at every width — cannot contain, however tight it is made. The operative bound must be a *floor on retained absorption*, not a cap on magnitude.

The primitive is not what separates these arms, and we state that rather than let the comparison imply it. Over the band an operator would actually authorize, the two models are indistinguishable on the safety outcome: neither trips any seed at the conformant -0.44 p.u. or at -0.33. On the area endpoint the override arm is in fact the *lower* of the two at every absorbing setpoint (-20.4 and -13.8 against -3.7 and $+4.7$), and at -0.11 it trips 1/5 seeds where curve modification trips all five. The pre-registered interpretation rule fixed in `run_curve_envelope.py` before the run — a non-degenerate band over which $\Delta J_V \leq 0$ and no seed trips — is met by *override* at -0.33 and by curve modification only at the conformant point itself, i.e. not at all; the released `results/derived_reported.json` records both bands. Had we read a primitive-level separation off these arms we would have been reading the shape of the two authorized sets — a two-sided magnitude cap for the setpoint against a one-sided absorption floor for the curve — and reporting it as a property of the feeder. Give the curve the two-sided cap and it fails as well ($\Delta J_V = 38.8$ at $+0.44$, every seed tripping); give the setpoint the floor and it contains.

One caveat runs the other way, and it does not rescue a primitive-level claim. The override arm's negative areas come from forcing full absorption at every node irrespective of local voltage, which absorbs more than the conformant curve; our one-sided overvoltage endpoint does not price the undervoltage that over-absorption causes on a feeder whose extremities already sag. The area comparison between the two models is therefore confounded, which is a further reason to rest the result on the zero point and the trip outcome rather than on the ordering of areas.

We accordingly withdraw the stronger claim — made in an earlier version of this section — that no reactive envelope both contains a compromise and delivers the volt-var service. It is false: an authorization holding the DER to at least about three quarters of the conformant Category B absorption trips no seed while still delivering volt-var. What we claim is that the containing property of that authorization is the excluded zero, which we measured, and not the function set that expresses it, which we did not.

There is a route by which the primitive could still matter, and it is a claim about the standard rather than about the feeder: if IEEE 2030.5 can express only a magnitude cap for `opModFixedVar` while a volt-var authorization can pin the characteristic's shape, then in deployment a fixed-setpoint grant always admits zero and the distinction becomes real. We flag this as a *conjecture we cannot verify*. It turns on `FunctionSetAssignments` expressiveness, row S7 of Table 1, for which our evidence is a clause number in the 2018-era profile and nothing in the edition in force. Resolving it needs the 2023 text we could not obtain, and until then the safe recommendation is primitive-independent: **authorize a reactive band that excludes zero absorption, by whichever function set carries it.**

Two limits on the measured part. The floor lies between -0.33 and -0.22 at five seeds and is not resolved more finely than that. And the earlier version's "narrow" envelope of 0.6 kvar is still not a counterexample: at 11.4% of the Category B range it does not deliver volt-var, and measured against legitimate operation rather than an empty feeder it breaches anyway ($\Delta J_V = 17.4$, trips in 4/5 seeds).

Consequence is strongly state dependent. Under normal load the same sweep gives a median $\Delta J_V \leq 12.0$ on the active axis and ≤ 11.4 on the reactive axis, with no trips at any envelope in any seed. Light load with high PV is the binding state, as Section 3 anticipates.

This attack is loud, and that matters.. At the conformant reactive envelope under light load a median 6958 of 8531 nodes (82%) sit above 1.05 p.u., with $v_{\max}$ at a median of 1.1383 p.u. and reaching 1.1424 in the worst seed. Most of that is the 62% already above band before any attack — what the attack adds is the 87.9 p.u.-node increment — but the post-attack state is still not a stealthy manipulation. It is a feeder-wide excursion that AMI voltage reporting, regulator operation counts, and customer complaints would surface within a single metering interval. Two conclusions follow. First, it weakens any narrative in which such a compromise quietly persists for a certificate's two-year lifetime: the operative containment latency becomes the utility's detection-and-response time, not the credential lifetime. Second, it identifies the attacker our evaluation does *not* cover — one who holds voltages just inside the ANSI band, or acts only during peak-PV minutes, would gain far more from long persistence precisely because nothing alarms, and that is exactly the case in which lifetime rather than detection binds. Our pre-registered protocol specifies an operationally realistic telemetry-limited attacker alongside the oracle worst case; the stealth-constrained variant is the more important of the two for this paper's thesis, and it is not yet run. We regard this as the most significant gap in the present evaluation.

Earlier sweeps, and why they are not reported as results.. Four further sweeps — PV penetration, attack family, a second feeder (IEEE 123), and a modeled retained-authority product $E_{\text{phys}} = \Delta J_V \times \text{BR}_{\text{auth}}$ — were run before the corrections of Section 6, on the superseded `Generator`-based harness and against a counterfactual feeder carrying no DER. Their legacy-baseline halves are directionally consistent with what is reported above, but we **do not report them**

as results: their ΔJ_V conflates connecting 7.2 MW of generation with stealing a credential, and their CONTAINDER halves sat at the inert 0.6 kvar envelope and read zero by construction. Three claims drawn from them are withdrawn: that narrow scope "retains the most common legitimate DER function while bounding the attack"; that moving from ephemeral to legacy persistence "multiplies light-load exposure roughly 1700×" (both cells share a scope, so the measured factor cancels and the ratio reduces to $17524/10 = 1752.4$, a quotient of two *assumed* lifetimes); and "neither half alone suffices" as argued from that product table. The runs remain under `results/superseded/` so the withdrawal can be checked.

Seed inventory.. Table 7 inventories every measured run behind this section, so no experiment's scale has to be inferred from prose.

Limitations.. These results are pilot results and we do not generalize them. Every physical result reported above comes from a *single* feeder, the IEEE 8500-node, on a single OpenDSS solver, with no GridLAB-D cross-check and a fixed export attacker; the IEEE 123 runs were made on the superseded harness and are withdrawn, and the PNNL 9500 system did not converge, so neither contributes a reported number. Table 7 gives the full seed inventory.

The IEEE 9500 failure mode, stated. The PNNL 9500-node system did not converge in our build, and we name the mode rather than leave it an unexplained absence. The failure is in the *base case*, with no attack and no PV of ours placed: the model's own shipped driver, unaltered, returns `Converged = False` with an empty error description and every bus per-unit magnitude reading zero — the solution collapses rather than missing tolerance. It reproduces at 1000 iterations, under both the normal and Newton algorithms, and with feeder controls enabled and disabled, so it is neither a control-loop oscillation nor an iteration-budget shortfall. Our build is DSS C-API 0.14.5 / DSS-Python 0.15.7 / OpenDSSDirect.py 0.9.4 on macOS arm64. **We did not resolve it and we do not attribute it**, having had no second OpenDSS build to discriminate a defect on our side from one in the model. Cross-feeder generality here therefore rests on nothing we report.

Overhead is workstation-only, with no constrained-hardware or TEE measurement. Availability injects verifier outages in-process rather than as networked failures; clock skew and renewal storms are untested. Interoperability against an unmodified IEEE 2030.5 endpoint is untested, and the clause-level delta between the 2018 and 2023 editions remains open pending access to the revised standard. Most importantly, what this evaluation supports is narrow: on one feeder at two operating states, bounding a fixed reactive setpoint does not contain while bounding the curve does, credential expiry ends the excursion promptly under light load, and the size of that second benefit is a lifetime the operator sets. It establishes no effect size for CONTAINDER. The pre-registered sweep — two feeders, a cross-solver check, seasonal states, constrained hardware, a stealth-constrained attacker and the full seed budget — is what would.

9. Related Work

We position CONTAINDER against ten strands of work; Table 8 compares it directly against the three closest systems.

IEEE 2030.5 and CSIP security. The 2018 and 2023 editions of IEEE 2030.5 mandate mutual TLS with X.509 device certificates [7, 8], constrained for interconnection by the Common Smart Inverter Profile [9]. The closest prior work is the 2030.5 security tutorial of Passos et al. [6], a survey that proposes no redesign, quantifies no feeder consequence, and formalizes no impact metric; Qi et al. survey the broader DER and smart-inverter surface [18]. The Sandia analysis supplies the revocation constraints we respect [1].

DER and smart-inverter attacks. High-wattage IoT botnets can move the grid [19, 20]; on the DER side, inverter attacks destabilize grid and market [21] and distribution voltage control is attackable under high PV [22], while the SUN:DOWN disclosure catalogs fleet-scale inverter vulnerabilities [23]. We tie the attack surface to the credential lifecycle rather than assuming device compromise.

Distribution-grid cyber-physical impact. False-data-injection work quantifies compromise consequence [24, 25, 26], grounded by the 2015 Ukraine incident [27] and quantitative risk formulations [28]; our feeder method is supporting, not novel.

Short-lived certificates and PKI lifecycle. ACME [29] and Let's Encrypt [30] automate issuance, SCEP [31] is the incumbent device enrollment, and HTTPS-ecosystem measurement quantifies the lifecycle problem [32]; we adopt short lifetimes as one link of a chain.

Hardware-bound identity. Secure device identity [12], firmware TPM [33], and hardware DICE [34] root our bootstrap layer.

Remote attestation. We use the RATS architecture [14], the Entity Attestation Token [13], and BRSKI [35], on established principles [36], adding fresh-key binding.

Attack-graph and cyber-physical metrics. Logic-based [2, 37, 38], probabilistic and Bayesian [3, 11, 10], and k-zero-day [4] metrics are static-snapshot and cyber-only; Section 3 shows what reachability-only reading omits, positioning our model as complementary.

Co-simulation. HELICS federates the cyber and grid models [39, 40] with GridLAB-D on the power side [41].

DER authorization. IEEE 1547 [16] defines the DER functions, DERMS perform feeder voltage management [42], and role-based access control [43] abstracts the scoping we narrow and enforce.

Revocation at scale. Web-PKI revocation delivery is gap-ridden [44], scalable revocation remains an open problem [45, 46], and even OCSP Must-Staple adoption is weak [47], which motivates containment by short-lived credentials rather than by revocation.

Workload identity: the closest existing system. SPIFFE and its SPIRE runtime [48, 49] implement almost exactly the chain we describe. SPIRE attests node and workload, issues short-lived scope-bound X.509 SVIDs keyed to the attested identity, refuses renewal when attestation fails, and relies on expiry rather than revocation; recent work extends it to IoT fleets [50] and nested tokens [51]. We must therefore answer whether CONTAINDER is workload identity with a DER label. Two differences are load-bearing. First, SPIFFE has no notion of a *physical effect that outlives the credential*: revoking a workload identity stops a process opening new connections but does not retract a volt-var curve already written into an inverter. Our T_{sess} and T_{cmd} enforcement exists because actuation persists in a way computation does not. Second, scope binds to `FunctionSetAssignments`, whose conformant settings are dictated by IEEE 1547-2018 [16] and CSIP [9] rather than chosen freely, so the *shape* of an authorized envelope is constrained by the profile rather than by the deployer — and it is that shape, not envelope width, that our result turns on. Whether the profile can express the absorption floor our result calls for is open (Section 8).

The Web PKI has already adopted non-renewal. The CA/Browser Forum defined a Short-lived Subscriber Certificate in 2023 and *exempted it from CRL and OCSP status checking* [52] — precisely "non-renewal replaces revocation", already ratified, with Baseline Requirements v2.2.8 setting the threshold at seven days [53] — and ballot SC-081v3 phases maximum TLS validity from 398 days to 47 by 2029 [54]. This is at once the strongest external validation of our premise and the sharpest limit on our novelty. We claim none for short-lived credentials or expiry-based containment. What we claim is the mapping onto DER authorization: which scope object to bind, which primitive to withhold, and that session and command-effect enforcement are separately necessary because grid actuation persists.

DER guidance and competing key management. IEEE 1547.3-2023 is the cybersecurity guide for interconnected DER [55] and the natural home for these recommendations; NISTIR 7628 [56] and IEC 62443 [57, 58] give the enclosing frameworks; NREL's DER certification line [59, 60] and gap analysis [61] document the certification landscape. IEC 62351 is the sharpest comparison: Part 8 gives role-based access control [62] and Part 9 specifies key management *including* enrollment and revocation for power-system equipment [63]. Part 9 is a directly competing answer, and the honest question is why 2030.5/CSIP does not adopt it. Not technical superiority on our side: 62351-9's revocation machinery assumes the connectivity and responsible-reporting party the Sandia analysis [1] found absent, and CSIP deployments certify against the 2030.5 profile. Where an operator has that connectivity, 62351-9 is a reasonable alternative, and we say so rather than claim the field.

10. Ethics and Responsible Disclosure

This work studies the consequences of credential compromise in order to bound them, and it carries a corresponding responsibility. All experiments use synthetic and lab-generated certificates. We use no real vendor keys or secrets, we test against no production DER fleet or any internet-reachable device, and we build no exploit tooling bound to a specific vendor product. The malicious dispatch programs exist only inside the feeder simulation and are never emitted to hardware.

The physical-consequence results describe what a compromised but protocol-conformant credential can already do under the deployed standard; they do not introduce a new vulnerability so much as measure an existing exposure that the standard's prohibition on revocation leaves unmitigated. The redesign and its migration path are offered as the constructive counterpart to the measurement: the point of quantifying the blast radius is to shrink it.

Disclosure and release, reconciled.. These two commitments are one timeline, not two. Nothing in this work identifies a vulnerability in a specific vendor product; what it identifies is a property of a published standard, which the standards body and the Sandia analysis [1] already describe in public. There is accordingly no embargoed finding whose disclosure must precede release. The artifact — code, result files, and pre-registration — is deposited and citable at the time of publication, which is the same event as public release. Should the confirmatory sweep identify a concrete weakness in a specific implementation, we will notify that implementer and the relevant standards body first and delay only the affected component of the release; the remainder is not held back.

11. Limitations and Conclusion

Limitations.. The boundaries of the evaluation are stated next to the results they bound, at the end of Section 8: one feeder and a single solver, one PV penetration level at the conformant scope envelope, modeled rather than measured retained authority, workstation-only overhead, in-process availability injection, untested interoperability, an unmeasured stealth-constrained attacker, and no access to the 2023 edition of the standard. Two further boundaries belong to the model. The authorization graphs used by the engine are synthetic, because real utility authorization graphs are not public; we mitigate this with a released parameterized generator and by ablating access-model permissiveness rather than fixing it. And our claims about revocation rest on the Sandia analysis rather than a clause-level reading of the edition in force.

Conclusion.. Credential compromise in IEEE 2030.5 is not well described by how many nodes an adversary reaches. It is described by how much physical capacity those nodes command, how long the adversary keeps it, and what the feeder does in response. Our central empirical finding is about the *shape* of the authorization an operator grants, not about how tightly it is drawn. **On the IEEE 8500-node feeder, a reactive authorization that permits zero absorption does not contain a credential compromise, and one that mandates a floor on absorption does.** An adversary needing no injection authority at all — commanding zero, which sits inside any magnitude bound — drives the feeder past an overvoltage trip threshold in every seed, because withdrawing the volt-var absorption is itself the attack. An adversary confined instead to a band holding at least about three quarters of the conformant Category B absorption trips no seed. Least privilege works here, but only when the bound is a floor rather than a ceiling.

We expected the control primitive to be what separated these cases and it is not: we ran the sweep under both a fixed-setpoint override and a bounded volt-var curve, and over the band an operator would authorize the two are indistinguishable on the trip outcome. Reporting a primitive-level separation would have described the shape of the two authorized sets we chose rather than anything the feeder did, so we do not. Whether the standard's function sets can express an absorption floor for a fixed setpoint is a question about IEEE 2030.5 that we could not answer without the edition in force, and we leave it flagged as a conjecture in Section 8.

Two things follow. The concrete one is a recommendation to the standard's users: authorize a reactive band that excludes zero absorption, by whichever function set carries it. The second is that scope discipline remains insufficient on its own at the envelopes deployments actually grant today, so bounding the *duration* of retained authority still matters, and that is what attested short-lived credentials with session and command-effect enforcement provide. The price is stated rather than hidden: containment latency is the credential lifetime divided by the per-cycle attestation detection probability, not the lifetime itself, and a gateway-proxy tier is the only one of our three deployment tiers that resolves the secure-time and constrained-hardware constraints the mechanism inherits from the problem it addresses. These are pilot results on one feeder; the pre-registered confirmatory sweep is what would generalise them.

Data availability

The analysis engine, the X.509/mutual-TLS credential service, the OpenDSS feeder experiment scripts, the pre-registration document, and every result file underlying the numbers reported here are provided as a single archive accompanying this submission, and will be deposited under a persistent identifier on acceptance; the archive is cited as reference [64]. Each reported numeral is checked against that archive by `check_numbers.py`, which fails if a numeral in the manuscript body cannot be located in the released result files. The IEEE 8500-node and IEEE 123-bus test feeders are publicly available from the referenced OpenDSS distributions. The one input we cannot redistribute is the IEEE 2030.5-2023 standard text itself, which is sold by IEEE; Section 2 states precisely which claims depend on it and which edition each was checked against.

Funding

This research received no specific grant from any funding agency in the public, commercial, or not-for-profit sectors.

Declaration of competing interest

The author declares that he has no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

CRediT authorship contribution statement

Huan Bui: Conceptualization, Methodology, Software, Validation, Formal analysis, Investigation, Data curation, Writing – original draft, Writing – review and editing, Visualization.

Declaration of generative AI and AI-assisted technologies in the writing process

During the preparation of this work the author used a large language model to assist with copy editing, LaTeX table formatting, and the drafting of code comments in the released artifact. After using this tool the author reviewed and edited the content as needed and takes full responsibility for the content of the published article. No generative AI tool was used to produce, analyse, or interpret any experimental result, and no text generated by such a tool was incorporated without verification against the underlying data.

References

[1] J. Obert, P. Cordeiro, J. Johnson, G. Lum, T. Tansy, M. Pala, R. Ih, Recommendations for trust and encryption in DER interoperability standards, Tech. Rep. SAND2019-1490, Sandia National Laboratories, Albuquerque, NM (Feb. 2019). doi:10.2172/1761841.

[2] X. Ou, S. Govindavajhala, A. W. Appel, MulVAL: A logic-based network security analyzer, in: 14th USENIX Security Symposium (USENIX Security 05), USENIX Association, 2005.

[3] L. Wang, T. Islam, T. Long, A. Singhal, S. Jajodia, An attack graph-based probabilistic security metric, in: Data and Applications Security XXII (DBSec 2008), Vol. 5094 of Lecture Notes in Computer Science, Springer, 2008, pp. 283–296. doi:10.1007/978-3-540-70567-3_22.

[4] L. Wang, S. Jajodia, A. Singhal, P. Cheng, S. Noel, k-zero day safety: A network security metric for measuring the risk of unknown vulnerabilities, IEEE Transactions on Dependable and Secure Computing 11 (1) (2014) 30–44. doi:10.1109/TDSC.2013.24.

[5] R. F. Arritt, R. C. Dugan, The IEEE 8500-node test feeder, in: IEEE PES T&D 2010, IEEE, 2010, pp. 1–6. doi:10.1109/TDC.2010.5484381.

[6] D. Passos, C. de Sousa, R. C. Gomes, D. F. de Assis, F. G. d. O. Passos, C. Albuquerque, A tutorial and security overview on the IEEE 2030.5-2018 standard, IEEE Communications Surveys & Tutorials 27 (6) (2025) 3615–3640. doi:10.1109/COMST.2025.3532110.

[7] IEEE, IEEE Standard for Smart Energy Profile Application Protocol, iEEE Standards Association (2018). doi:10.1109/IEEESTD.2018.8608044.

[8] IEEE, IEEE Standard for Smart Energy Profile Application Protocol, iEEE Standards Association; published Dec. 2024 (2023). doi:10.1109/IEEESTD.2024.10785536.

[9] SunSpec Alliance, Common Smart Inverter Profile (CSIP): IEEE 2030.5 Implementation Guide for Smart Inverters, version 2.1 Edition, released 15 March 2018; supports CA Rule 21 Phase 2 (Mar. 2018).

[10] N. Poolsappasit, R. Dewri, I. Ray, Dynamic security risk management using bayesian attack graphs, IEEE Transactions on Dependable and Secure Computing 9 (1) (2012) 61–74. doi:10.1109/TDSC.2011.34.

[11] M. Frigault, L. Wang, Measuring network security using bayesian network-based attack graphs, in: 2008 32nd Annual IEEE International Computer Software and Applications Conference (COMPSAC), IEEE, 2008, pp. 698–703. doi:10.1109/COMPSAC.2008.88.

[12] IEEE, IEEE Standard for Local and Metropolitan Area Networks—Secure Device Identity (2018). doi:10.1109/IEEESTD.2018.8423794.

[13] L. Lundblade, G. Mandyam, J. O'Donoghue, C. Wallace, The entity attestation token (EAT), RFC 9711, Internet Engineering Task Force (IETF) (Apr. 2025). doi:10.17487/RFC9711.

[14] H. Birkholz, D. Thaler, M. Richardson, N. Smith, W. Pan, Remote ATtestation procedures (RATS) architecture, RFC 9334, Internet Engineering Task Force (IETF) (Jan. 2023). doi:10.17487/RFC9334.

[15] A. Anderson, S. Vadari, J. Barr, S. Poudel, A. Dubey, T. McDermott, R. Podmore, Introducing the 9500 node distribution test system to support advanced power applications: An operations-focused approach, Tech. Rep. PNNL-33471, Pacific Northwest National Laboratory (PNNL), u.S. DOE Office of Scientific and Technical Information (2022). doi:10.2172/1922914.

[16] IEEE, IEEE Standard for Interconnection and Interoperability of Distributed Energy Resources with Associated Electric Power Systems Interfaces (2018). doi:10.1109/IEEESTD.2018.8332112.

[17] National Electrical Manufacturers Association (NEMA), American National Standard for Electric Power Systems and Equipment—Voltage Ratings (60 Hz), revision of ANSI C84.1-2016; reaffirmed 2025 (2020).

[18] J. Qi, A. Hahn, X. Lu, J. Wang, C.-C. Liu, Cybersecurity for distributed energy resources and smart inverters, IET Cyber-Physical Systems: Theory & Applications 1 (1) (2016) 28–39. doi:10.1049/iet-cps.2016.0018.

[19] S. Soltan, P. Mittal, H. V. Poor, BlackIoT: IoT botnet of high wattage devices can disrupt the power grid, in: 27th USENIX Security Symposium (USENIX Security 18), USENIX Association, 2018, pp. 15–32.

[20] T. Shekari, A. A. Cárdenas, R. Beyah, MaDIoT 2.0: Modern high-wattage IoT botnet attacks and defenses, in: 31st USENIX Security Symposium (USENIX Security 22), USENIX Association, 2022, pp. 3539–3556.

[21] X. Hui, S. Karumba, S. C.-K. Chau, M. Ahmed, Destabilizing power grid and energy market by cyberattacks on smart inverters, in: Proceedings of the 16th ACM International Conference on Future and Sustainable Energy Systems (e-Energy '25), ACM, 2025, pp. 136–151. doi:10.1145/3679240.3734613.

[22] Y. Isozaki, S. Yoshizawa, Y. Fujimoto, H. Ishii, I. Ono, T. Onoda, Y. Hayashi, Detection of cyber attacks against voltage control in distribution power grids with PVs, IEEE Transactions on Smart Grid 7 (4) (2016) 1824–1835. doi:10.1109/TSG.2015.2427380.

[23] Forescout Vedere Labs, SUN:DOWN: Destabilizing the grid via orchestrated exploitation of solar power systems, Vulnerability research report, Forescout Technologies, industry (non-peer-reviewed) report; 46 vulnerabilities across Sungrow, Growatt and SMA, not all CVE-assigned (Mar. 2025).
URL `https://www.forescout.com/research-labs/sun-down-a-dark-side-to-solar-energy-grids/`

[24] Y. Liu, P. Ning, M. K. Reiter, False data injection attacks against state estimation in electric power grids, in: Proceedings of the 16th ACM Conference on Computer and Communications Security (CCS '09), ACM, 2009, pp. 21–32. doi:10.1145/1653662.1653666.

[25] R. Deng, G. Xiao, R. Lu, H. Liang, A. V. Vasilakos, False data injection on state estimation in power systems—attacks, impacts, and defense: A

survey, IEEE Transactions on Industrial Informatics 13 (2) (2017) 411–423. doi:10.1109/TII.2016.2614396.

[26] G. Liang, J. Zhao, F. Luo, S. R. Weller, Z. Y. Dong, A review of false data injection attacks against modern power systems, IEEE Transactions on Smart Grid 8 (4) (2017) 1630–1638. doi:10.1109/TSG.2015.2495133.

[27] G. Liang, S. R. Weller, J. Zhao, F. Luo, Z. Y. Dong, The 2015 Ukraine blackout: Implications for false data injection attacks, IEEE Transactions on Power Systems 32 (4) (2017) 3317–3318. doi:10.1109/TPWRS.2016.2631891.

[28] A. Teixeira, K. C. Sou, H. Sandberg, K. H. Johansson, Secure control systems: A quantitative risk management approach, IEEE Control Systems Magazine 35 (1) (2015) 24–45. doi:10.1109/MCS.2014.2364709.

[29] R. Barnes, J. Hoffman-Andrews, D. McCarney, J. Kasten, Automatic certificate management environment (ACME), RFC 8555, Internet Engineering Task Force (IETF) (Mar. 2019). doi:10.17487/RFC8555.

[30] J. Aas, R. Barnes, B. Case, Z. Durumeric, P. Eckersley, A. Flores-López, J. A. Halderman, J. Hoffman-Andrews, J. Kasten, E. Rescorla, S. Schoen, B. Warren, Let's encrypt: An automated certificate authority to encrypt the entire web, in: Proceedings of the 2019 ACM SIGSAC Conference on Computer and Communications Security (CCS '19), ACM, 2019, pp. 2473–2487. doi:10.1145/3319535.3363192.

[31] P. Gutmann, Simple certificate enrolment protocol (SCEP), RFC 8894, Internet Engineering Task Force (IETF) (Sep. 2020). doi:10.17487/RFC8894.

[32] Z. Durumeric, J. Kasten, M. Bailey, J. A. Halderman, Analysis of the HTTPS certificate ecosystem, in: Proceedings of the 2013 Internet Measurement Conference (IMC '13), ACM, 2013, pp. 291–304. doi:10.1145/2504730.2504755.

[33] H. Raj, S. Saroiu, A. Wolman, R. Aigner, J. Cox, P. England, C. Fenner, K. Kinshumann, J. Löser, D. Mattoon, M. Nyström, D. Robinson, R. Spiger, S. Thom, D. Wooten, fTPM: A software-only implementation of a TPM chip, in: 25th USENIX Security Symposium (USENIX Security 16), USENIX Association, 2016, pp. 841–856.

[34] L. Jäger, R. Petri, DICE harder: A hardware implementation of the device identifier composition engine, in: Proceedings of the 15th International Conference on Availability, Reliability and Security (ARES '20), ACM, 2020, pp. 1–8. doi:10.1145/3407023.3407028.

[35] M. Pritikin, M. Richardson, T. Eckert, M. Behringer, K. Watsen, Bootstrapping remote secure key infrastructure (BRSKI), RFC 8995, Internet Engineering Task Force (IETF) (May 2021). doi:10.17487/RFC8995.

[36] G. Coker, J. Guttman, P. Loscocco, A. Herzog, J. Millen, B. O'Hanlon, J. Ramsdell, A. Segall, J. Sheehy, B. Sniffen, Principles of remote attestation, International Journal of Information Security 10 (2) (2011) 63–81. doi:10.1007/s10207-011-0124-7.

[37] P. Ammann, D. Wijesekera, S. Kaushik, Scalable, graph-based network vulnerability analysis, in: Proceedings of the 9th ACM Conference on Computer and Communications Security (CCS '02), ACM, 2002, pp. 217–224. doi:10.1145/586110.586140.

[38] S. Jajodia, S. Noel, B. O'Berry, Topological analysis of network attack vulnerability, in: Managing Cyber Threats: Issues, Approaches, and Challenges, Vol. 5 of Massive Computing, Springer, 2005, pp. 247–266. doi:10.1007/0-387-24230-9_9.

[39] T. D. Hardy, B. Palmintier, P. L. Top, D. Krishnamurthy, J. C. Fuller, HELICS: A co-simulation framework for scalable multi-domain modeling and analysis, IEEE Access 12 (2024) 24325–24347. doi:10.1109/ACCESS.2024.3363615.

[40] B. Palmintier, D. Krishnamurthy, P. Top, S. Smith, J. Daily, J. Fuller, Design of the HELICS high-performance transmission-distribution-communication-market co-simulation framework, in: 2017 Workshop on Modeling and Simulation of Cyber-Physical Energy Systems (MSCPES), IEEE, 2017, pp. 1–6. doi:10.1109/MSCPES.2017.8064542.

[41] D. P. Chassin, K. Schneider, C. Gerkensmeyer, GridLAB-D: An open-source power systems modeling and simulation environment, in: 2008 IEEE/PES Transmission and Distribution Conference and Exposition, IEEE, 2008, pp. 1–5. doi:10.1109/TDC.2008.4517260.

[42] I. Rahman, N. Selak, E. Paaso, Distributed energy resource management system (DERMS) solution for feeder voltage management for utility integrated DERs, in: 2021 IEEE Power & Energy Society Innovative Smart Grid Technologies Conference (ISGT), IEEE, 2021, pp. 1–5. doi:10.1109/ISGT49243.2021.9372281.

[43] R. S. Sandhu, E. J. Coyne, H. L. Feinstein, C. E. Youman, Role-based access control models, Computer 29 (2) (1996) 38–47. doi:10.1109/2.485845.

[44] Y. Liu, W. Tome, L. Zhang, D. Choffnes, D. Levin, B. Maggs, A. Mislove, A. Schulman, C. Wilson, An end-to-end measurement of certificate revocation in the web's PKI, in: Proceedings of the 2015 Internet Measurement Conference (IMC '15), ACM, 2015, pp. 183–196. doi:10.1145/2815675.2815685.

[45] J. Larisch, D. Choffnes, D. Levin, B. M. Maggs, A. Mislove, C. Wilson, CRLite: A scalable system for pushing all TLS revocations to all browsers, in: 2017 IEEE Symposium on Security and Privacy (SP), IEEE, 2017, pp. 539–556. doi:10.1109/SP.2017.17.

[46] T. Smith, L. Dickinson, K. Seamons, Let's revoke: Scalable global certificate revocation, in: Proceedings 2020 Network and Distributed System Security Symposium (NDSS), Internet Society, 2020. doi:10.14722/ndss.2020.24084.

[47] T. Chung, J. Lok, B. Chandrasekaran, D. Choffnes, D. Levin, B. M. Maggs, A. Mislove, J. Rula, N. Sullivan, C. Wilson, Is the web ready for OCSP must-staple?, in: Proceedings of the Internet Measurement Conference 2018 (IMC '18), ACM, 2018, pp. 105–118. doi:10.1145/3278532.3278543.

[48] The SPIFFE specification: Secure production identity framework for everyone, `https://github.com/spiffe/spiffe`, specification set: SPIFFE ID and Verifiable Identity Document, SPIFFE Workload API, SPIFFE Workload Endpoint, X.509-SVID, JWT-SVID; accessed 2026-07-31 (2025). URL `https://github.com/spiffe/spiffe`

[49] SPIFFE: Secure production identity framework for everyone, Cloud Native Computing Foundation graduated project, accepted to CNCF 2018-03-29; incubating 2020-06-22; graduated 2022-08-23 (2022). URL `https://www.cncf.io/projects/spiffe/`

[50] D. Bakoyiannis, G. Kornaros, O. Tomoutzoglou, M. D. Grammatikakis, M. Coppola, Trusting IoT devices at scale in the computing continuum through SPIFFE/SPIRE certificates, in: Applications in Electronics Pervading Industry, Environment and Society (ApplePies 2024), Lecture Notes in Electrical Engineering, Springer, 2025, pp. 279–285. doi:10.1007/978-3-032-17174-0_40.

[51] H. Z. Cochak, C. C. Miers, P. H. B. Correia, M. A. Marques, M. A. S. Jr., Lightweight SPIFFE verifiable identity document (LSVID): A nested token approach for enhanced security and flexibility in SPIFFE, in: CloudCom, 2024, pp. 9–16. doi:10.1109/CLOUDCOM62794.2024.00015.

[52] CA/Browser Forum, Ballot SC063v4: Make OCSP optional, require CRLs, and incentivize automation, passed; voting period 2023-07-06 to 2023-07-13; introduced the Short-lived Subscriber Certificate into Baseline Requirements v2.0.0 (Jul. 2023). URL `https://cabforum.org/2023/07/14/ballot-sc063v4-make-ocsp-optional-require-crls-and-incentivize-automation/`

[53] CA/Browser Forum, Baseline requirements for the issuance and management of publicly-trusted TLS server certificates, short-lived Subscriber Certificate defined in Section 1.6.1; validity periods in Section 6.3.2; 47-day maximum effective 2029-03-15 (2026).
URL https://cabforum.org/working-groups/server/baseline-requirements/requirements/

[54] CA/Browser Forum, Ballot SC081v3: Introduce schedule of reducing validity and data reuse periods, approved; voting period 2025-04-04 to 2025-04-11 (Apr. 2025).
URL https://cabforum.org/2025/04/11/ballot-sc081v3-introduce-schedule-of-reducing-validity-and-data-reuse-periods/

[55] IEEE, IEEE guide for cybersecurity of distributed energy resources interconnected with electric power systems, Tech. Rep. IEEE Std 1547.3-2023, Institute of Electrical and Electronics Engineers, iEEE Xplore document 10352402 (Dec. 2023). doi:10.1109/IEEESTD.2023.10352402.

[56] The Smart Grid Interoperability Panel–Smart Grid Cybersecurity Committee, Guidelines for smart grid cybersecurity, Tech. Rep. NISTIR 7628 Revision 1, National Institute of Standards and Technology, Gaithersburg, MD (Sep. 2014). doi:10.6028/NIST.IR.7628r1.

[57] IEC, Industrial communication networks – network and system security – part 3-3: System security requirements and security levels, Tech. Rep. IEC 62443-3-3:2013, International Electrotechnical Commission (Aug. 2013).
URL https://webstore.iec.ch/en/publication/7033

[58] IEC, Security for industrial automation and control systems – part 4-2: Technical security requirements for IACS components, Tech. Rep. IEC 62443-4-2:2019, International Electrotechnical Commission (Feb. 2019).
URL https://webstore.iec.ch/en/publication/34421

[59] W. Hupp, D. Saleem, J. T. Peterson, K. Boyce, Cybersecurity certification recommendations for interconnected grid edge devices and inverter based

resources, Tech. Rep. NREL/TP-5R00-80581, National Renewable Energy Laboratory, Golden, CO (Nov. 2021). doi:10.2172/1832209.

[60] D. Saleem, M. Slowinske, Cybersecurity certification standard for distributed energy and inverter based resources, Tech. Rep. NREL/PR-5R00-81827, National Renewable Energy Laboratory, Golden, CO, conference presentation; OSTI 1842981 (Jan. 2022).
URL https://www.osti.gov/biblio/1842981

[61] C. MaGill, D. Saleem, J. Waggoner, J. deCastro, DER cybersecurity standards: Assessment and gap analysis, Tech. Rep. NLR/TP-5T00-93100, National Laboratory of the Rockies, Golden, CO (2026). doi:10.2172/3015061.

[62] IEC, Power systems management and associated information exchange – data and communications security – part 8: Role-based access control for power system management, Tech. Rep. IEC 62351-8:2020, International Electrotechnical Commission, withdrawn 2026-07-22 and superseded by IEC 62351-8:2026; cited here as the edition in force during this work (Apr. 2020).
URL https://webstore.iec.ch/en/publication/61822

[63] IEC, Power systems management and associated information exchange – data and communications security – part 9: Cyber security key management for power system equipment, Tech. Rep. IEC 62351-9:2023, International Electrotechnical Commission, second edition; cancels and replaces IEC 62351-9:2017 (Jun. 2023).
URL https://webstore.iec.ch/en/publication/66864

[64] H. Bui, [dataset] CONTAINDER: analysis engine, attested credential service, OpenDSS feeder pipeline, pre-registration, and result files, Zenodo, DOI pending deposit (2026).

Table 5: Two reactive authorization models at matched magnitude (IEEE 8500, five paired seeds). q_{high} is the reactive setpoint commandable at the top of the voltage range, in p.u. of nameplate apparent power; negative is absorption. *Curve* leaves the volt-var controller enabled and bounds how far the characteristic may move; *override* disables it and writes a fixed setpoint, as `opModFixedVar` does. "Trip" counts only seeds where the screen fires and did *not* already fire in that seed's legitimate base case (the light-load base trips in none). **Read the rows, not the columns:** at zero commanded reactive power the area rises and every seed trips under *both* models, which is the reported result. Neither model trips a seed at −0.44 or −0.33, so the columns do not separate over the band an operator would authorize; where they differ the override column is the lower one on area, and at −0.11 it trips fewer seeds. The negative override areas reflect absorption forced at every node irrespective of local voltage, which this one-sided overvoltage endpoint does not penalise.

	light load / high PV				normal	
	curve		override		curve	override
q_{high}	ΔJ_V	trip	ΔJ_V	trip	ΔJ_V	ΔJ_V
$-0.44^{\dagger}$	−3.7	0.0	−20.4	0.0	0.1	−0.1
−0.33	4.7	0.0	−13.8	0.0	0.9	0.2
−0.22	13.1	0.2	−6.8	0.6	0.1	0.5
−0.11	20.4	1.0	10.8	0.2	0.1	1.4
+0.00	31.4	1.0	31.2	1.0	1.0	2.0
+0.11	23.0	0.6	28.0	1.0	1.8	1.4
+0.22	29.8	1.0	54.5	1.0	0.5	5.8
+0.33	32.0	1.0	71.6	1.0	2.1	5.4
+0.44	38.8	1.0	87.9	1.0	5.6	11.4

† the conformant IEEE 1547-2018 Category B value.

Table 6: Active-power scope sweep, IEEE 8500 feeder: median induced overvoltage area ΔJ_V (p.u.-node) against legitimate volt-var operation, and the fraction of five paired seeds in which the IEEE 1547 Category II overvoltage trip screen fires. The reactive axis is reported separately in Table 5. Negative entries are neither noise nor reactive "support": against a counterfactual in which PV generates at full scheduled output, an adversary held below σ=0.7 is *curtailing*, so voltage rise and the one-sided area both fall. A restrictive active-power scope thus converts the compromise into an unwanted-curtailment problem — an availability and revenue harm this endpoint does not price — rather than an overvoltage one. An earlier version read such values as "marginally supporting" voltage, which is backwards: support would *increase* the area.

	light load / high PV		normal	
Authorized envelope	ΔJ_V	trip	ΔJ_V	trip
Active-power axis ($\sigma\times$ nameplate, `DERControl`)				
$\sigma = 0.0$	-56.0	0.00	-0.07	0.00
$\sigma = 0.5$	-30.3	0.00	-0.33	0.00
$\sigma = 0.7$	-1.3	0.60	0.17	0.00
$\sigma = 0.8$	22.1	1.00	1.49	0.00
$\sigma = 1.0$	63.1	1.00	11.98	0.00

Table 7: Inventory of the measured runs this section reports. Seeds are paired across arms within an experiment; "arms" counts the policy or envelope conditions evaluated at each seed. The superseded-harness runs are inventoried separately in `results/superseded/`.

Experiment	Seeds	Arms	States
IEEE 8500 time series	20	9	2
Credential-lifetime sweep	20	18	2
Scope-envelope sweep	5	21	2
Volt-var-curve sweep	5	18	2
Control-mode diagnostic	1	2	1
Credential-service invariants (C1)	1	10	—
Overhead microbenchmarks (C3)	500 iterations	4	—
Availability fault injection (C6)	3 policies	3	—

Table 8: Positioning against representative prior work. y = yes, n = no, p = partial, – = n/a.

Work	2030.5	Scope	Time	Phys.	Attest.	Proto.	Feeder
Attack-graph metrics [2, 3, 4]	n	p	n	n	n	–	n
2030.5 security survey [6]	y	p	n	n	n	n	n
Attestation building blocks [14, 13, 12]	n	p	p	p	y	p	n
CONTAINDER (this work)	y	y	y	y	y	p*	p*

y = addressed; p = partial; n = not addressed; – = not applicable. *Partial: a prototype and a pilot feeder evaluation are reported in Section 8; native-client interoperability, constrained hardware, and the full pre-registered sweep are not yet done.